Vendor Risk Assessment Report

CloudDesk Inc.:Customer Support SaaS platform

Prepared for	CISO FinServe India Pvt Ltd
Prepared By	Rolfin ,TPRM Analyst
Date	06 October 2026
Vendor tier	Tier 1 – Critical (score 4.35/5.00)

1.Executive Summary

Recommendation: APPROVE WITH CONDITIONS
Residual risk: HIGH (inherent High, control maturity 2.25 / 5). Onboarding proceeds only after the gates in Section 5.
Six findings: 1 Critical, 4 High, 1 Medium. Two questionnaire answers (Q4 and Q7) are contradicted by the SOC 2 report

CloudDesk will process customer PII and KYC-linked identifiers for about 1.2 million FinServe customers. It has very good disaster recovery and encryption, but its SOC 2 Type II report carries a qualified opinion on logical access, and the report shows that several questionnaire answers overstate the vendor's controls.

Top risks: MFA is missing for admins although the questionnaire says it is enforced (Q7). Terminated employee's access is removed late (Q4).A 7-day breach notice cannot support a 72-hour regulatory timeline (Q8); and customer data has no scheduled deletion (Q9), which conflicts with DPDP Act and GDPR retention principles .

2.Scope and Method

Service	Customer Support and ticketing
Data	Customer PII,KYC – linked identifiers, call recordings
Evidence	SOC 2 Type II , SIG questionnaire, draft MSA
Method	1)Tier the vendor , 2)Review questionnaire,3)Review SOC ,4)Cross-checked answer against evidence , 5)Score the question test , 6)Log the findings and Decide

3.SOC 2 Review

Checklist Item	Result	Status
Type and period	Type II, 12 months	Pass
Opinion	Qualified	Flag
Scope	Privacy criteria not covered	Flag
Exceptions	1:CC 6.1 leavers	Flag
Subservice Organisations	AWS	Flag
CUECs	4 CUECs assigned to FinServe owners	Pass
Report age	98 days since period end	Flag

4.Scoring and Findings

Domain	Weights	Score	Weighted
Access Control & IAM	25%	1	0.25
Encryption &Key Management	20%	3	0.60
Vulnerability & Patch Management	10%	2	0.20
Incident Response	15%	2	0.30
Privacy & Data Protection	15%	2	0.30
Governance &Risk management	15%	4	0.60
Control maturity score	100%		2.25

Maturity band is “Developing” with inherent risk High which gives residual risk High. So the decision rule gives “**Approve with Conditions**”.

ID	Finding	Severity	Mapped Controls	SLA
V-01	MFA not enforced for privileged and administrative access	Critical	NIST SP 800-53 IA-2(1) |ISO 27001:2022	30 days (before go-live
V-02	Encryption keys stored in the same environment as the data	High	NIST SP 800-53 SC-12 |ISO 27001:2022 A.8.24	60-days
V-03	Late access revocation for leavers	High	ISO 27001:22 A.6.5	60-days
V-04	Breach notification commitment is 7 days, too slow for 72 hours regulatory timelines	High	GDPR Art.33(2) | DPDP Act.s.8(6)|NIST SP 800-53 IR-6	Before contract signature
V-05	No scheduled deletion and retention of customer data	High	DPDP Act s.8(7) | GDPR Art.17 |NIST SP 800-53 SI-12 |ISO 27001:2022 A.8.10	Clause before contract signature
V-06	Independent penetration test is older than 12 months	Medium	NIST SP 800-53 CA-8 | ISO 27001:2022 A.8.8 | PCI DSS V4.0 11.4	90-days

5. Recommendations and conditions

I recommend conditional approval. Rejection is not needed because the gaps can be fixed and the vendor has a credible SOC2 programme. Unconditional approval is not appropriate because a Critical finding affects the privileged access to the customer.

Gate	Condition	Deadline
Before contract signature	Breach notice within 24 hours. Retention, deletion, destruction clause	30 Oct 2026
Before go-live	MFA with evidence. SOC 2 bridge letter, AWS SOC 2	05 Nov 2026
After go-live	V-02 AND V-03 within 60 days, V-06 within 90 days, with temporary risk acceptance	05 Dec 2026

Monitoring: quarterly check-ins on open findings and annual reassessment (6 October 2027).
Limitations: Simulated,No technical testing of the vendor , regulatory references are not legal advice